Appunti di Information Security Governance & Cyber Security

Super Scaletta! - Von Solms' Model

1. **Governance**
2. **Tactical**
3. **Operational**

Directives → **Direct Control** → **execute**

Control | **Risk Management** | **Awareness** | **Organization**

- ↳ **Input:** External (legal, regulations) and internal (vision, goals) factors
- ↳ **Output:** Directives concentrating on asset protection
- ↳ **Control:**
  - ↳ **Input:** Measurement
  - ↳ **Output:** Report with extracted operational data.

2 core principles of the front dimension:

1. Accountability at the highest level.
2. Separation between governance and management.

Information Security Policy Architecture (ISPA)

1. Board-initiated Directive about ISG.
2. Corporate Information Security Policy (CISP) from directives.
3. Set of sub-Policies from CISP.
4. Set of company standards based on policies.
5. Set of operational procedures.
6. Set of identified IT-assets and the board mandate to protect them.

Board Dir. → CISP → sub-policies → procedures

Note: All sub-policies must be linked or traced back to CISP.

NIST CSF (Cybersecurity Framework)

1. **Identify:** Organizational understanding of cybersecurity risk.
2. **Protect:** Develop and implement safeguards for critical services.
3. **Detect:** Develop and implement controls to identify the occurrence of events.
4. **Respond:** Dev. and imp. actions to a detected incident.
5. **Recover:** Dev. and imp. actions to maintain and restore services.

Implementation Tiers:

(Partial → Risk Informed → Repeatable → Adaptive)

- **Tier 1:** Ad-hoc management, no collaboration.
- **Tier 2:** Management approval but no clear policies, not all levels involved.
- **Tier 3:** Regularly updated policies, regularly updated but not continuous.
- **Tier 4:** Standards and best practices, continuous improvement process.

NIST CSF 2.0

New govern function:

↳ Roles, responsibilities and structure
↳ Policy development
↳ Risk management strategy
↳ Resource allocation
↳ Compliance

National Cybersecurity Framework

Non mandatory tool, based on NIST CSF but adapts Priority and Maturity levels, adds GDPR.

↳ **Mapped requirements:** managing companies apply Technical and Organizational measures (TOMs) like encryption to ensure compliance.

Standard ISO

Pagina 3

- **ISO 27001:** Certifiable standard defining strict requirements for an Information Security Management System (ISMS).
  Very specific and strict, as compliant companies get certified. It is Risk-Based: requires to assess specific risks and treat them according to its own needs. *(It's the WHAT)*
- **ISO 27002:** Is a "guideline" document that advises companies on what to have to follow "Best Practice". *(It's the How-To)*
  Is a dictionary of security controls to support Direct and Control phases. It's voluntary and cannot be certified.

  Anatomy of a Control:
  - ↳ **Control statement:** The what, short definition of sec. measure.
  - ↳ **Implementation Guidance:** The how, step by step advice on how to do it.
  - ↳ **Other information:** legal considerations, contextual details.
- **ISO 27005:** Is the Risk Management manual. Is a non-certifiable guide on how to satisfy risk requirements in ISO 27001.
- **ISO 27014:** Information Security governance guidelines.
- **ISO 27018:** Code of practice for protection of personally identifiable info (PII).
- **ISO 27032:** Guidelines for Cybersecurity.
- **ISO 31000:** A more complete Risk guideline. Called Enterprise Risk Management (ERM), is high level guidelines to manage ANY type of risk (from financial to safety) that an organization might face.

Gestione del Rischio (Risk Management)

Pagina 4

5. Risk Treatment

Identify risks and select means for risk mitigation and reduction. They balance the cost of treatment with the cost of harm.

- ↳ **Risk reduction:** reducing likelihood or consequence of incidents.
- ↳ **Risk Retention:** Accepting the risk consciously.
- ↳ **Risk Avoidance:** avoiding the activity that creates the risk.
- ↳ **Risk Sharing:** transferring the risk to another party.

6. Monitoring and Review (M&R)

Continual checking to identify deviations from expected status. Review determines the effectiveness of the RM process.

Purpose:

- ↳ Ensure controls are effective and efficient.
- ↳ Get info to improve risk assessment.
- ↳ Learn from incidents.
- ↳ Identify emerging risks.

Involves checking asset values, threats, vulnerabilities.

Cyber Risk Assessment

Unlike the Risk Assessment which is a practical application of ISO 31000, Cyber risk assessment is a practical application of ISO 27005, as its focus is on Information Technology and Data.

The main differences are:

- ↳ Threats can come from anywhere.
- ↳ The Threats sources can be intentional or accidental (Malicious or not).

So in the Risk Identification step, we add the identification of:

- ↳ **Malicious Cyber risk:** consider who, why, where and how.
- ↳ **Non-Malicious Cyber risk:** technical weaknesses, lack of awareness, incidents.

High Consequence Risk - Low Likelihood & Auditing

Pagina 5

Rischi ad Alto Impatto e Bassa Probabilità:

1. **Black Swan:** Extremely rare event with severe consequences, but also unpredictable. Best option is contingency planning.
2. **Grey Swan:** Event with major impact but some predictability.

They are often overlooked if undocumented or poor communication.

- Use qualitative scale.
- Balance prevention cost with residual risk severity.

Auditing

Systematic and independent evaluation of processes (and documented) for obtaining evidence and evaluating it objectively against established criteria.

IT Auditors goal: verify the CIA triad.

Assurance

Independent and objective evaluation that provides confidence to stakeholders. Risk Management creates confidence, Assurance validates the confidence.

Levels:

- ↳ Reasonable assurance
- ↳ Limited assurance
- ↳ No assurance

(Remember that negative results still provide assurance)

Also reliable evidence must be credible, verifiable and traceable.

Audit Process

1. **Planning:** Define objectives.
2. **Understanding the system:** Gather context and identifying results.
3. **Risk assessment:** Determine inherent and control risks.
4. **Designing Tests:** Establish audit procedures and sampling.
5. **Collecting Evidence:** Execute fieldwork and document results.
6. **Evaluating results:** Collect evidence.
7. **Reporting:** Write and summarize findings.

Control Types & Audit Frameworks

Control Types

- ↳ **Preventive Controls:** Stop errors or incidents before occurring.
- ↳ **Detective Controls:** Identify errors after occurring.
- ↳ **Corrective Controls:** Restore normal conditions.

The Audit Toolkit

Risk-Control-Test Relationship (RCM)

Each risk maps to one or more controls, and each control is verified through specific tests. This Matrix (RBACM) provides transparency, linking Audit scopes and evidence with organizational risk priorities.

Assurance Standards (Audit Reports)

- ↳ **ISAE:** It's a standard used by auditors to conduct reporting and focuses on the quality and reliability of the internal controls (framework for reporting).
  - ↳ **Type I:** evaluates the design and implementation of controls.
  - ↳ **Type II:** all in Type I + test the operating effectiveness of controls.
- ↳ **SOC (Service Organization Control):** American framework, report that is result of the audit, it focuses on specific criteria and scope relevant to the user.
  - ↳ **SOC 1:** For financial auditors, controls of the user financial statements.
  - ↳ **SOC 2:** Board, Management, regulators, stakeholders. Control over CIA, privacy, security.
  - ↳ **SOC 3:** Summary of SOC 2 but for public use ("seal of approval").

Specialized Audit Areas and Methods

- **GDPR:** Audits assess compliance with data protection principles and verify the existence of TOMs.
  - **TOMs:** Technical measures (encryption, ...) and Organizational measures (policies).

Diagrammi e Metodologie di Rischio

Pagina 7

Data Flow Diagram (DFD)

Graphical representation of flow data, high level view of how information system manages assets.

Elements:

- **External entity:** people or code outside your control
- **Data flow:** Communication between processes, or processes and data stores
- **Process:** Any running code
- **Data store:** Things that store data

Attack Trees

Represents the possible attack paths of an attacker in your system.

- **Root node:** goal of the attack
- **Leaf nodes:** specific attacks used to reach the goal. (Can use AND/OR)

Threat Elicitation

- Iterating over each node and considering if that issue impacts your system.

Incident Management

1. **Preparation:** Prepare and prevent incidents
   - Define communication plans
   - Provide analysis tools
   - Risk Assessment
   - Malware prevention
   - User training
   - Maintain documentation
   - Creation of a Jump Kit

↓

OWASP Risk Rating Methodology

- ↳ Threat agents: entities that might attack
- ↳ Exploitability: current state of exploit techniques
- ↳ Weakness Prevalence: how known is the weakness
- ↳ Weakness Detectability: likelihood of discovery
- ↳ Technical impacts: impact on app, data and used functions
- ↳ Business impacts: damage to the company (reputation, money)

Cybersecurity Certification Process

Pagina 8

1. **Preparation:** perform internal auditing, management reviews for governance and audits.
2. **Preliminary evaluation:** the certification body reviews documentation, logs and interviews key roles. If issues, time to fix is given.
3. **Operative Inspection:** checking systems, logging etc... and vulnerability assessment.
4. **Proposal and Release:** The cert body submits the result to a technical committee. If accepted, the certification is released.
5. **Monitoring:** Once a year, external auditors verify compliance (no advice/auditor experience).
6. **Renewal:** After 3 years the process restarts.

Accreditation vs. Certification

- **Accreditation:** evaluating bodies that give certification, ensuring competence.
- **Certification:** Independent verification that a product/service meets requirements.

Risk Based Auditing (RBA)

Pagina 9

Unlike traditional Auditing, RBA prioritizes high risk domains to ensure efficient resource allocation. To calculate the **Audit Risk (AR)** we need:

- ↳ **Inherent Risk (IR):** caused by absence of internal control (likelihood)
- ↳ **Control Risk (CR):** likelihood of failure of internal controls to prevent or detect
- ↳ **Detection Risk (DR):** likelihood that the auditor process fails to detect a material error

Structure:

1. **Plan:** define objectives and scopes for auditing. Also define the Benchmark if policy is missing (framework).
2. **Assess Risk:** Identify and rank risks (IR, CR).
3. **Design Tests:** design specific tests to address the identified high risk areas (interviews, check logs, scan, crack hashes).
4. **Execute:** collect evidence from tests previously designed and analyze it (like saying that a critical vulnerability path was found).
5. **Evaluate Results:** compare evidence with established criteria (benchmark). So do Gap analysis and root cause analysis.
6. **Report:** Summarize findings and recommendations.

7. **Follow-Up:** action plan agreement to fix issues, and timed verifications.

It's not exclusively internal audit. It can also be used by external auditors to assure external stakeholders.

Von Solms' Model (Approfondimento)

Pagina 10

Front dimension: Governance

1. **Strategic level:** Is the domain of top management and board of directors. Not interested in day to day but rather in identifying critical assets, set direction and avoid unmitigated risks.
2. **Tactical and operational (Management):** Focus on how to achieve the strategic goals and where things are actually done. Operational is day-to-day stuff such as patching, firewalls and updating controls.

Control phase: operates on the philosophy that *"you can only control what you can measure"*. As operational data is extracted, it flows upward to the Tactical level for compliance monitoring and then to the Strategic level: Provides the board with specialized reports and "Situational awareness".

Depth:

Involves outlining the specific pillars that span across all management levels to make ISG work.

↳ **Directives:** explain high-level basis for all low-level documents in ISPA. CISP is the basis for sub-policies → standards → procedures.

↳ **Control:** *"you can only control what you can measure"*. These perform compliance checks across the ISPA, so it must define Compliance Clauses (specific rules that provide a clear metric capable of being evaluated by audits (ICT)).

NIST Standards & Audit Process

Pagina 11

They provide the foundational building blocks for governance, conducting risk assessment and managing incident.

NIST places a massive emphasis on governance. **NIST SP 800-100** defines ISG as a process of establishing management structure to ensure that IS strategies align with business objectives.

NIST also gives guidance on how to handle security breaches.

Auditing

↳ **Internal auditing:** Before seeking formal verification, they conduct internal audits to verify the controls and policies required by the standards.

↳ **External auditing:** Periodic reviews conducted by independents with proven experience.

Risk-Based Audit Process

It's an auditing process that focuses on the most critical risks rather than treating all systems the same.

- **Step 1: Planning and context establishment.** Need to define the focus, scope and target by understanding internal and external context. Must identify business objectives, critical assets and external dependencies.
- **Step 2: Identifying key risks.** That means identifying the assets, vulnerabilities and threats (malicious / non-malicious).
- **Step 3: Evaluating controls.** Auditor assesses the security controls and countermeasures of the company and checks if they are theoretically adequate, well designed and compliant with the best practices.

Monitoring, Auditor Role & Incident Lifecycle

3. Monitoring and the role of the external auditor

After releasing the certification, the organization enters a monitoring phase. Once a year, an external auditor checks the conformity level on the most critical risks first. The auditor must remain impartial.

The auditor is forbidden from suggesting solutions or mitigating risks.

4. Renewal and Economic Impact

After 3 years the certification expires, triggering the renewal phase. During this phase, the auditor must check any and all changes that happened by going back to the preliminary evaluation.

Incident Management

Is the structured project aimed at identifying, analyzing and correcting hazards to prevent future re-occurrence. It directly concerns overall management of the organization.

NIST Lifecycle

Phase 1: Preparation. This phase is twofold:

1. First, the organization prepares to handle incidents by establishing communication facilities, analysis tools, and jumpkits.
2. Second, they focus on preventing incidents by keeping the volume of incidents low (Risk assessment, network security, malware prevention, and training).

SOC (Security Operations Center)

So the primary goal is to strengthen an organization's security by proactively detecting and responding, ultimately minimizing the potential impact on business operations.

When to adopt?

↳ **Critical data:** when moving critical data and processing that requires strict regulatory compliance.
↳ **Organizational growth:** creates bottlenecks and organization struggles to keep up.
↳ **Advanced needs:** when there's a need for pushed monitoring.

Services:

- **Core services:**
  ↳ **Log Management:** collecting and analyzing and monitoring logs from various systems.
  ↳ **Security Monitoring and Alerting:** observing the IT environment for anomalies and generating prioritized alerts to enable rapid detection.
  ↳ **Security Incident Management:** identifying, responding to, and resolving security incidents to minimize business impact.
- **Extra services:** Security Operation Management and Vulnerability Assessment.

Triad of Security Operations

SOC is built with the foundation that skilled personnel are supported by robust processes.

- **People:** relies on skilled personnel, internal training, on-the-job experience, and tool training.
- **Technology:** Systems supporting operations (Incident Detection/Management, Threat Intelligence, Forensics...)
- **Process:** Protocols on how the SOC handles events.

CERT / CSIRT

A specialized group of experts whose primary purpose is to assist in responding to cybersecurity incidents.

Framework

- ↳ **Mission:** The goal is to enable organizations to anticipate, survive and recover from cyber incidents.
- ↳ **Constituency:** Unlike SOC which covers a single network, CERT is defined by a group of entities it serves, from National CERTs, Sector-Specific CERTs to Regional CERTs.
- ↳ **Responsibility:** Governance decides what incidents the CERT handles, priorities and if the CERT needs to actively solve incidents or only notify and advise constituents.
- ↳ **Mandate:** Can CERT have the power to issue binding deadlines to solve incidents? Can it gather data for forensics?
- ↳ **Organizational framework:** Define relationship and escalation path with CISO, CIO, external entities.

Services

- ↳ **Preventive and Proactive:** Issuing alerts and warnings on cyberattacks, vulnerability analysis and coordination...
- ↳ **Education and Training.**
- ↳ **Information dissemination:** Unlike SOC, CERT interacts with external organizations to share intelligence and coordinate defense strategies.